Incident Zero: AI On-Call Engineer architecture

Bosch × PES University hackathon · team of 5 · rules first, LLM as a gated fallback, human approval for every change

P1 Eyes · P2 Detect, eval, verify · P3 Brain: rules · P4 Brain: LLM & reports · P5 Hands · LLM model runs here · HUMAN person decides · escalate to a human

TOOLS & EVIDENCE

Read-only tools P1

metrics
Prometheus
traces, dependencies
Jaeger
logs
OpenSearch / docker logs
container health
Docker

✕ never queries flagd or the flag UI/API
✕ strips feature_flag data from traces

used in steps 2, 4, 5, 7 and 12

Evidence ledger P1

ID, typed facts, anomaly onset time
read by steps 8 and 13

DETECT & DIAGNOSE

1 **Alert watcher** P2
Prometheus thresholds: error rate, p95, restarts

2 **Triage snapshot** P2
per service: errors, p95, resources, onset times

4 **Find suspects** P3
dependency graph → ranked candidates, not just deepest

5 **Rank hypotheses** P3
anomaly, timing, traces, support vs contradiction

6 **Diagnosis state**
≥ 0.7, clear margin?

confident

uncertain

unknown

8 **Validator** P4
IDs exist, values match, facts support each claim

still unknown, or evidence fails checks

fingerprint

3 **Incident memory** P1
fingerprint similarity; reorders suspects only

ranking

LLM

7 **LLM investigator** P4
competing hypotheses; ≤ 8 calls, no action tools

validated diagnosis, one cause at a time

store if verified

SAFETY CONTROLS

Guardrails P5

- kill switch checked before every call
- dry-run mode for every action
- append-only action log
- one service per action
- ≤ 1 action before verifying
- ≤ 2 actions per incident
- one rollback, then escalate

DECIDE & ACT

symptoms remain: re-triage and re-diagnose (max 2 actions per incident)

9 **Remedy + tier** P5
table → allowlisted fix; checks target, tier, conf.

HUMAN

10 **Approval gate** P5
kill switch off, dry run, explicit human yes

yes

11 **Execute** P5
Action API only; every call logged

12 **Verify recovery** P2
re-check metrics 2–3 min; decides rollback (P5 runs it)

ok

LLM

13 **Report & learn** P4
JSON + readable report, facts from ledger only

Escalate
stop and hand the findings to the on-call human; a report is still written

tier 3 or below threshold

rejected

not recovered after rollback

AUTONOMY TIERS

every state change needs human approval; the tier sets how strict it is

Tier 0 · autonomous
read-only tools, dry runs, reports, escalating

Gate: none

Tier 1 · quick approve
restart one stateless service, throttle the load generator

Gate: confidence ≥ 0.7, then yes/no

Tier 2 · strict approve
toggle a flag, restart cache or DB, scale a service

Gate: ≥ 0.85, dry run, type service name

Tier 3 · never act
off-allowlist, multi-service, repeat action, or below tier confidence

Gate: escalate with findings

Code makes every decision that changes the system. The LLM runs only in boxes marked LLM, never sees flag data and has no action tools. Memory and timing change how suspects are ranked, never confidence directly. No rule refers to an incident ID.

Thresholds are starting values, calibrated on the practice incidents.